



CSE 4531: E-Commerce and Web Security

Quiz: 1

Duration: 30 minutes

Total Marks: 15

Date: 22-12-25

Answer all three (3) questions. Place the boxes in the right margin indicate marks of each question

Student ID: 220041135

1. The ride-sharing application provides drivers with a profile update form through which they can modify their own vehicle description (illustrated in figure 1.1).

Figure 1.1: Profile update form used by drivers to edit vehicle details (entry point for user input).

When the form is submitted, the backend executes the following SQL query:

```
UPDATE drivers
SET vehicle_info = '$vehicle'
WHERE driver_id = $did;
```

Where:

- `$vehicle` contains the vehicle description entered by the driver through the form.
- `$did` is the authenticated driver's ID obtained from the session.

Only the `vehicle_info` field is intended to be editable through this form.

The `drivers` table contains a column named rating, which drivers are **not authorized** to modify. For example, Alice, a legitimate driver, currently has a rating of 4.8.

Assume that:

- User input is **not sanitized**.
- Prepared statements are **not used**.
- Eve, a malicious driver, knows Alice's `driver_id` which is "DID042".

Eve intends to reduce **Alice's rating from 4.8 to 1.2**. Demonstrate an SQL injection attack by specifying the input Eve **could enter in the Vehicle Description field** to modify Alice's rating.

Your answer must clearly specify the injected payload with a brief explanation.

2. A trusted e-commerce website allows customers to submit product reviews. These reviews are stored in the database and later displayed on product pages exactly as submitted.

Alice, a legitimate customer, is authenticated while browsing product pages. Eve, a malicious user, notices that JavaScript code included in a product review is executed in the browsers of users who view the affected product page.

Answer the following:

- Briefly explain how Eve can inject malicious code. 2.1
- Briefly explain why the application stores the malicious code. 1
- Briefly describe, step by step, how the injected script executes in Alice's browser. 2.

3. For each of the following security goals— 3.1

- Confidentiality,
- integrity,
- Availability

—do the following:

- Briefly describe a realistic scenario in which the security goal is compromised in an e-commerce system.
- Mention the technical mechanism or type of attack that leads to the compromise.
- Briefly discuss the impact of the compromise on the system, stored data, and end users.